

VULNERABILIDADES CRÍTICAS, CVEs Y VERSIONES AFECTADAS

CVE	Nombre Común / Tipo	Versiones de Windows Server Afectadas	Impacto y Mecanismo de Ataque	Mitigación Técnica (Hardening)
CVE-2026-25177	AD DS Privilege Escalation	Server 2012 / 2012 R2 Server 2016 Server 2019 Server 2022 / 2025	Crítico (CVSS 8.8). Inyección de caracteres Unicode que evade la verificación de duplicados SPN/UPN, permitiendo a usuarios comunes escalar a SYSTEM y comprometer el dominio.	Aplicar de inmediato el parche acumulativo (Patch Tuesday) y monitorear modificaciones inusuales de atributos SPN en los controladores de dominio.
CVE-2025-21293	Active Directory Elevation of Privilege	Server 2012 / 2012 R2 Server 2016 Server 2019 Server 2022 / 2025	Control de acceso incorrecto ([CWE-284]) que permite a usuarios con credenciales básicas alterar descriptors de seguridad heredados y ganar derechos de administrador de dominio.	Aplicar el parche acumulativo, restringiendo y auditando las operaciones LDAP y los accesos remotos RPC a los controladores de dominio.
CVE-2021-34527	PrintNightmare (RCE / EoP)	Server 2008 / 2012 R2 Server 2016 Server 2019 Server 2022	Crítico. El servicio Print Spooler acepta controladores maliciosos de usuarios autenticados, permitiendo la ejecución de código remoto con máximos privilegios.	Deshabilitar Print Spooler vía GPO en todos los servidores que no sean de impresión dedicados.
CVE-2020-1472	Zerologon (Netlogon EoP)	Server 2008 R2 Server 2012 / 2012 R2 Server 2016 Server 2019	Crítico (CVSS 10.0). Falla criptográfica en Netlogon que permite cambiar la contraseña del controlador de dominio de forma externa y sin credenciales.	Forzar por directiva el uso estricto de <i>Secure RPC</i> para Netlogon y bloquear algoritmos heredados.
CVE-2016-20925	Windows NTLM Spoofing Flaw	Server 2008 / 2012 R2 Server 2016 Server 2019 Server 2022 / 2025	Medio / Alto. Control defectuoso en rutas NTLM que permite ataques de suplantación, forzando a un host interno a interactuar con recursos malignos externos.	Deshabilitar la autenticación NTLM antigua, migrar integralmente a Kerberos y forzar SMB Signing.
CVE-2017-0144	EternalBlue (SMBv1 RCE)	Server 2008 / 2008 R2 Server 2012 / 2012 R2 Server 2016 (Nota: Server 2019 lo trae deshabilitado por defecto, pero sigue expuesto si se activa)	Histórico / Crítico. Desbordamiento de búfer en SMBv1 que permite la inyección y ejecución de código a nivel de Kernel, facilitando ataques como el Ransomware WannaCry.	Desinstalar la característica física de SMBv1 mediante PowerShell: Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol

Resumen de lo aprendido

En esta practica, aprendí a realizar lo siguiente:

1. Identificar vectores de ataque: Analizar fallos en protocolos de red y brechas en Active Directory.
2. Evaluar riesgos: Detectar parches desactualizados y debilidades críticas de configuración en el sistema.
3. Mitigar amenazas: Ejecutar técnicas de hardening para contener de inmediato la elevación de privilegios.
4. Proteger infraestructura: Implementar perímetros de seguridad robustos para blindar los entornos corporativos.